



The virtual CISO every small business can finally afford.

Live in production • real customers, real data

SEED ROUND • \$900,000

Derrick Brooks, Founder & CEO • Xandu Limited, LLC

THE PROBLEM

Every business is a target.
Almost none can afford protection.

\$200K–\$400K

Annual cost of a full-time CISO

99%

of US businesses are small/mid-sized —
they can't afford that

43%

of all cyberattacks target small
businesses (Verizon DBIR)

Yet insurers, customers, and regulators now require a real security program — there is no more “we'll get to it.”

The pressure just became unavoidable.



Cyber-insurance as gatekeeper

Insurers now require proof of controls before issuing or renewing policies.



Customer-driven requirements

Larger customers push security questionnaires down to their small vendors.



Expanding regulation

HIPAA, CMMC, the FTC Safeguards Rule, and state privacy laws now reach the small-business tier.



AI makes it economical

Expert-level guidance is now deliverable at a cost that fits a small-business budget.

THE SOLUTION

ShieldAI — a virtual CISO, powered by AI, overseen by engineers.

THE OLD WAY

- A PDF from a one-time consulting engagement
- \$200K+/year for a full-time hire
- Static advice that's stale in a month
- No monitoring, no proof of controls

THE SHIELDAI WAY

- A continuous, living security program
- Priced as a subscription, from \$0
- Real, defensible NIST/CIS posture score
- Live threat intel, monitoring, and audit-ready evidence

HOW IT WORKS

Assess → Score → Generate → Monitor → Manage



Assess

Conversational intake + 12-framework checklist



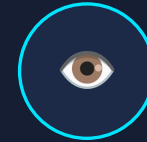
Score

Deterministic NIST/CIS engine — not AI guesswork



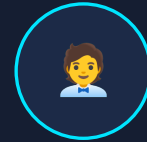
Generate

Policies, roadmap, training, compliance, exec report



Monitor

Read-only agent
(Win/Linux/macOS) + real
CVE intel



Manage

Analyst console:
continuous oversight +
expert review

SEE IT WORK

A real, live product — not slideware.

CLIENT EXPERIENCE

- Assessment → real posture score
- Full program: policies, roadmap, compliance
- Live CVE & dark-web threat exposure
- Tier badge, usage panel, upgrade flow

ANALYST / ADMIN CONSOLE

- Portfolio command center, per-client drill-in
- Strict client isolation, enforced server-side
- ShieldAI Mastermind — AI co-pilot with real tool-use
- Review & approve every AI-drafted deliverable

demo@shieldai.com · analyst@xandultd.com

STRATEGY

Land free, expand through five tiers, grow into managed programs.



BUSINESS MODEL

Recurring revenue that grows with the relationship.

MOST POPULAR

Free

\$0/mo

Starter

\$159/mo

Growth

\$349/mo

Guided

\$699/mo

Managed

\$1,950/mo

~\$0.28/client/mo AI cost (measured) • ~25 clients per engineer • ~75% managed-tier margin, ~60% blended

Revenue mechanics are live today: Stripe checkout, billing portal, and webhook-driven tier and add-on changes.

MARKET SIZE

A large, underserved market being forced to act.



~5.8M

U.S. employer businesses (36.2M small businesses total)

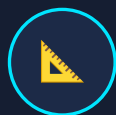
~\$2B+

vCISO category today, growing 12-15%+ annually

600K-1.2M

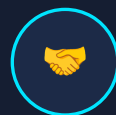
regulated / insured / supply-chain serviceable segment

Not a wrapper. A defensible system — and it's already built.



Proprietary scoring methodology

Explainable, auditor- and insurer-trusted — not an opaque AI guess.



Human-in-the-loop

Expert review makes output trustworthy enough to sell, and limits liability.



Compounding data & relationships

Every assessment and managed client makes the system smarter and stickier.



Live and monetizable today

12-framework compliance, real threat intel, live billing, a live analyst console.

The AI is the commodity; the system around it — methodology, workflow, engineers, data — is the moat.

WHAT THIS RAISE UNLOCKS

The platform is built. This raise buys people and distribution.

LIVE TODAY

Full client product · 12-framework compliance · real CVE/dark-web threat intel · read-only monitoring agent · five-tier billing · live analyst console · Mastermind AI co-pilot with tool-use

THIS RAISE

Hire the first cybersecurity engineers onto the live console · go-to-market & channel partnerships · SOC 2 readiness

THEN

Agent telemetry → continuous automated alerting · deepen framework coverage · grow the managed book

Use of funds: 42% engineers · 29% go-to-market · 16% platform depth · 10% ops/SOC 2 · 3% reserve

We're raising \$900,000

to staff and scale a managed-security platform that's already built.

Series A readiness by Month 18

~\$3M ARR annualized run-rate at that
point

Proven managed-tier unit economics

“A full-time CISO costs a quarter-million dollars a year. ShieldAI delivers that protection for the price of a subscription — and lets a handful of our engineers protect thousands of businesses.”

Appendix

Reference slides for Q&A

Derrick Brooks — Founder & CEO

- Former U.S. Navy Lieutenant Commander — 20+ years in risk management, compliance, and IT infrastructure
- Built enterprise security programs from the ground up; administered \$200K+ budgets; led teams of up to 195
- Delivered attack-surface reductions of up to 80% via Zero Trust architecture, Azure cloud migration, and automated vulnerability management
- Offensive practitioner: penetration testing across web apps, cloud infrastructure, and connected-device APIs; remediated tens of thousands of vulnerabilities, including for a major automotive manufacturer
- Deep command of NIST, RMF, CMMC, ISO 27001, and FedRAMP
- CISSP · CISM · CompTIA Security+ · Double M.S. in Cybersecurity (National University) · MBA in IT Management (SNHU)
- Doctorate in Cybersecurity in progress — Westcliff University

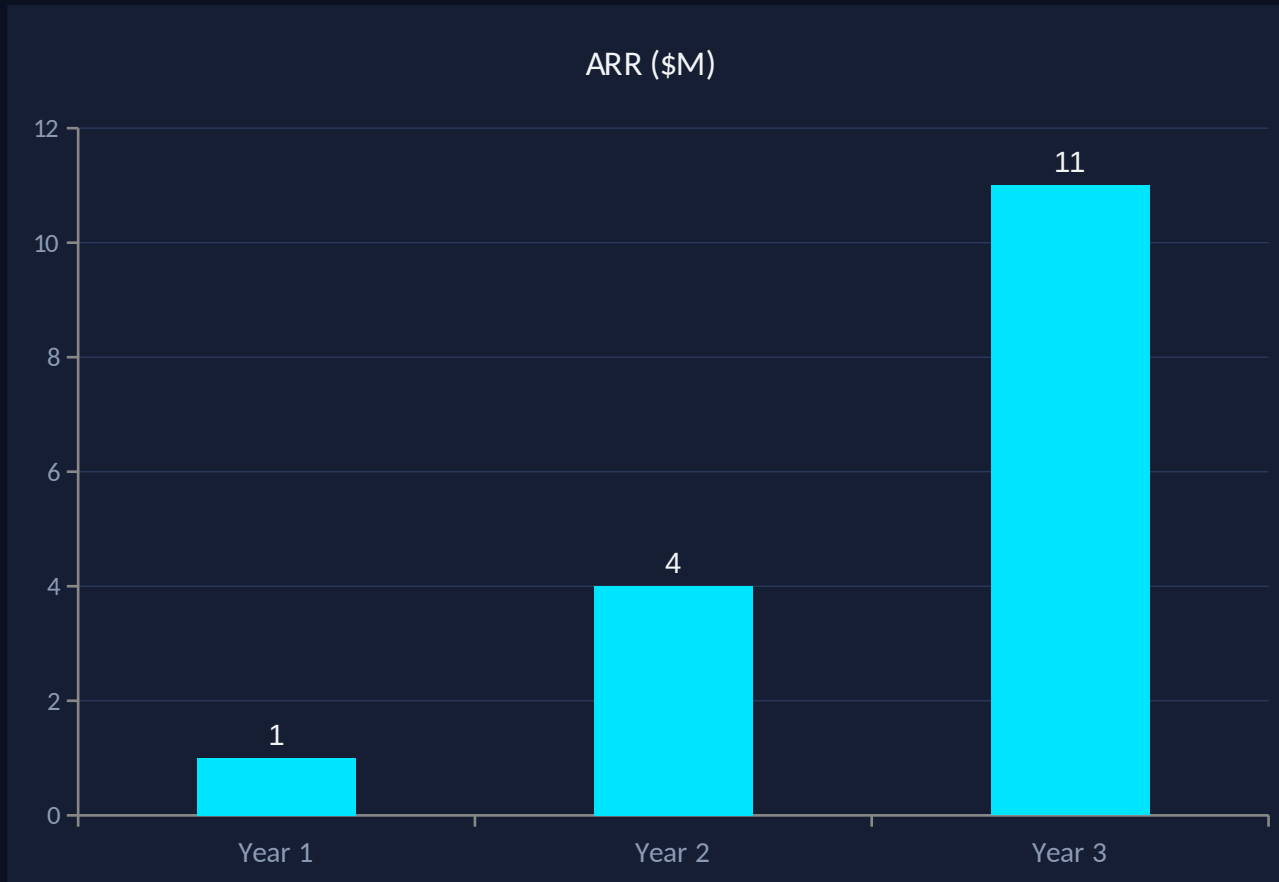
COMPETITION

An honest landscape — and an uncontested lane.

Category	Examples	Limitation	ShieldAI Edge
Traditional vCISO	Fractional CISO, FRSecure, Kroll	Human-only, expensive, mid-market+	AI does the heavy lifting
AI-native vCISO	Cynomi, RealCISO, Trava	Cynomi sells to MSPs, not direct-to-SMB	Direct-to-SMB + managed hybrid
GRC / scoring tools	SecurityScorecard, CyberSaint	Scoring only, not a full program	Complete program + delivery
MSPs / DIY tools	Managed IT add-ons, templates	No CISO-level judgment	We deliver the CISO function

Cynomi advises MSP customers not to price under \$1,500/month — leaving the sub-\$1,500 direct-to-SMB lane ShieldAI targets structurally uncontested by the category's best-known player.

Three-year ramp — platform leverage, not linear headcount.



	Year 1	Year 2	Year 3
Total paying clients	270	915	2,370
Security engineers	1	5	23
Blended gross margin	~55%	~58%	~60%

Managed clients — not total clients — drive engineer hiring, at ~25 clients/engineer. ARR grows roughly 4x faster than headcount: the signature of a platform, not a consultancy.

Two hard boundaries, by design — not policy.

AI advises, humans act

Mastermind is read-only and advisory. It has no ability to change a client's systems, execute a task, or take any action — every deliverable is either deterministically computed or reviewed and approved by a human before it reaches the client.

Analyst isolation

An analyst can only ever reach clients explicitly assigned to them, enforced server-side on every route — not a UI convention. Cross-client access is structurally impossible, not merely discouraged.

Read-only monitoring agent

The Windows/Linux/macOS agent observes and reports. It accepts no inbound commands — there is no channel for it to receive instructions, by construction.

Human-reviewed liability posture

Every client-facing legal, insurance, and compliance document carries a review disclaimer and is built for licensed-professional review before reliance.

What's enforced at each tier — backend-first, not a UI gate.

Tier	Price	Endpoints	Policies	Threat Intel	Analyst Support
Free	\$0	—	—	—	—
Starter	\$159/mo	5	6	—	—
Growth	\$349/mo	25	10	✓	—
Guided	\$699/mo	100	Unlimited	✓	Limited
Managed	\$1,950/mo	Unlimited	Unlimited	✓	Full

Training delivery is bundled at Growth and above; available as a \$40/mo add-on for Starter. Limits are enforced server-side with structured HTTP 402 responses — UI gating is presentation only.

Deterministic, explainable, and free of AI guesswork.

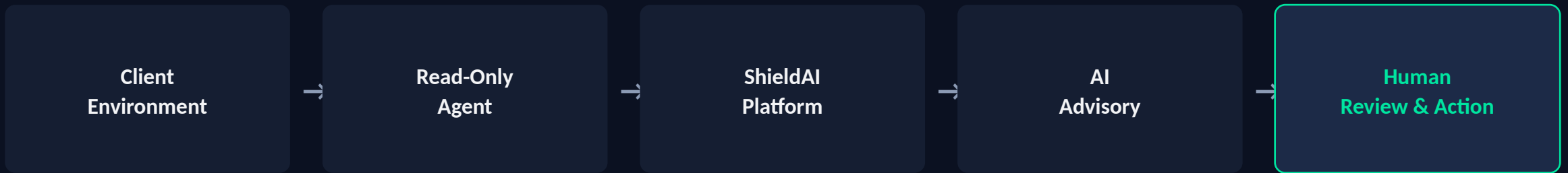
NIST CSF ENGINE

- Five weighted functions: Identify, Protect, Detect, Respond, Recover
- Same inputs always produce the same score — no AI variance
- Every point traces to a specific, citable control

CIS CONTROLS V8.1 LENS

- Alternative or companion scoring view, client's choice
- Implementation-Group scoped (IG1/IG2/IG3)
- 12 compliance frameworks map onto the same assessment data — no duplicate intake

The read-only boundary: the agent and the AI never act.



× No inbound command channel exists anywhere left of “Human Review & Action.”

- The monitoring agent observes and reports only — it cannot receive instructions from the platform, by construction, not configuration.
- Mastermind (the AI advisory layer) can look up data on demand but cannot change a client's systems, status, or account state.
- Only a client admin, or an analyst the client has explicitly permitted, can take action — every consequential change is attributable to a human.